

Plantilla de Reporte Ejecutivo – Indicadores ISO 27001 con GQM + PRAGMATIC

Diapositiva 1 – Título

- Título: Estado de los indicadores de ciberseguridad (ISO 27001, GQM + PRAGMATIC)
- Subtítulo: Resultados de la encuesta y análisis para [organización / sector / territorio]
- Datos: fecha, logos, responsables.

Diapositiva 2 – Por qué este ejercicio

- Cambio de enfoque: de “tener indicadores” a “tener indicadores que respondan a objetivos claros y sean útiles”.
- Alineamiento con ISO 27001, ISO 27004 y NIS2.
- Mejora de la trazabilidad entre objetivos nacionales, objetivos de negocio y datos técnicos.

Diapositiva 3 – Metodología en 2 palabras: GQM + PRAGMATIC

- GQM:
- Objetivos – Preguntas – Métricas.
- Trazabilidad descendente. [web:40][web:43][web:51]
- PRAGMATIC:
- Predictive, Relevant, Actionable, Genuine, Meaningful, Accurate, Timely, Independent, Cheap. [web:44][web:52]
- Filtro de calidad para cada métrica.

Diapositiva 4 – Perfil de la muestra

- Nº de organizaciones, sectores, tamaños.
- Estado de certificación ISO 27001.
- Breve comentario sobre representatividad.

Diapositiva 5 – IGM (Índice Global de Madurez)

- Gráfico con IGM medio, mínimo, máximo, cuartiles.
- Clasificación por niveles (1-5).
- Mensaje: en qué nivel se sitúa el sistema de indicadores.

Diapositiva 6 – Subíndices GQM por familia

- Gráfico radar o barras por objetivos GQM:
- G-MAD-1 (madurez), G-RISK-1, G-TECH-1, G-INC-1, G-AWARE-1, G-RES-1, G-SUP-1, G-REG-1, G-GOV-1.
- Destacar 2-3 puntos fuertes y 2-3 áreas de mejora.

Diapositiva 7 – Calidad de las métricas (PRAGMATIC)

- Promedio de puntuaciones PRAGMATIC por grupo de métricas.
- Gráfico que muestre, por ejemplo: P, R, A y M vs C (coste).
- Mensaje: ¿tenemos métricas predictivas y accionables o, más bien, históricas y decorativas?

Diapositiva 8 – Riesgos y exposición técnica

- Principales resultados de:
- M-RISK-ASSETS, M-RISK-TREATED, M-RISK-OVERAPP.
- M-TECH-CRIT-MTTR, M-TECH-EXPOSED, M-TECH-SUPPORTED.
- Conexión con el riesgo de incidentes significativos.

Diapositiva 9 – Incidentes, SOC y resiliencia

- Datos clave:
- M-INC-MTTD, M-INC-MTTR, M-INC-SLA, M-INC-SEV, M-RES-RTO-MEET.
- Interpretación: capacidad real de detección y recuperación frente a escenarios críticos.

Diapositiva 10 – Factor humano

- Resultados de:
- M-AWARE-COVER, M-AWARE-PHISH-CLICK, M-AWARE-PHISH-REPORT.
- Mensaje: nivel de riesgo por ingeniería social y cultura de reporte.

Diapositiva 11 – Terceros y regulación

- Métricas de proveedores: M-SUP-CRIT-EVAL, M-SUP-INC.
- Índice de alineamiento con NIS2, métricas de brechas de datos (M-REG-NIS2-ALIGN, M-REG-BREACH).
- Cómo se compara esto con expectativas reguladoras y tendencias nacionales/europeas.

Diapositiva 12 – Gobierno de métricas

- Nivel de automatización (M-GOV-AUTO).
- Percepción de calidad de datos (M-GOV-DATAQUAL).
- Conclusión: cuán robusta es la “fábrica de indicadores” que alimenta al SGSI.

Diapositiva 13 – ROI y perspectiva económica

- Resultados de ROI de seguridad para las organizaciones que aporten datos.
- Ejemplos: coste por punto de IGM, coste por incidente evitado.
- Mensaje: cómo traducir mejoras en indicadores a valor económico y reducción de riesgo.

Diapositiva 14 – Prioridades de mejora

- Principales brechas identificadas por GQM y PRAGMATIC.
- Lista de 4–5 acciones prioritarias (por ejemplo, reforzar métricas de terceros, mejorar MTTR, automatizar recogida de datos críticos, etc.).

Diapositiva 15 – Hoja de ruta propuesta

- Corto plazo (0–6 meses): limpieza de métricas, selección y ajustes rápidos.
- Medio plazo (6–18 meses): integración en GRC/BI, mejora de automatización, reforzar métricas de alta puntuación PRAGMATIC.
- Largo plazo (> 18 meses): modelos de predicción, indicadores avanzados, plena integración en gestión de riesgos y planificación.

Diapositiva 16 – Cierre

- Recordatorio: un SGSI sin métricas útiles es difícil de gestionar; métricas sin objetivo ni calidad son puro ruido.
- Invitación a decidir: qué métricas se adoptan como “core”, qué métricas se retiran y qué proyectos se priorizan en base a los resultados.